20/06/2026

CSE-405

think adversarially about computer systems
assess threat
build robust systems → reduce damage

security property → mapping (9)
↳ enforcing a desired property in the presence of an attacker.

confidentiality → nobody can read the msg except the sender & recv. even if they get hold of it

integrity → ensuring that the data is not tampered.

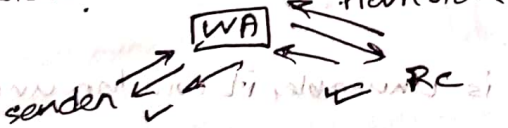
authentication → proof of identity ⇒ verification

authorization → permission ⇒ differs across users.

availability → avoiding downtime, minimizing damage during downtime.

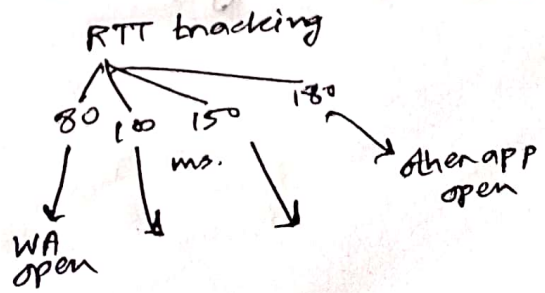
* Operation Olympic games.
* digital signature with programs → used by trusted publishers.
* zero day vulnerability ⇒ just released ..

What is hackable?



delivery receipt

spamming ~~error~~ reactions → state of recv → no rate limits → wastes BW of recv 1B GB/hr.



↳ contain/minimize model

Security principles → mapping to scenarios, short notes.

* know your threat model ⇒ what the attacker can do?
  why an attack might happen?
  - money
  - politics
  - retaliation
  - fun

  } mainly these 3

(PPI model)
— Packet Instruction

Common assumptions for attackers -
* can interact w/o prior notice
* knows general info about systems
* can get lucky. ⇒ 6 digit pwd ⇒ assume attacker will try 1M times.

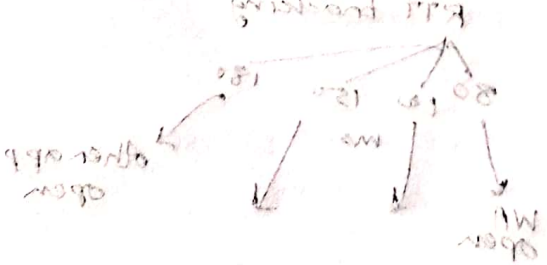
Trusted Computing Base ⇒ components of a system that security relies upon. (TCB)
e.g. Authentication Handler
Authorization
Permission Manager

properties of TCB:
- Completeness
- Connectness
- Security

(TCB) security critical components
generally made as small as possible.

* Consider Human Factors: ⇒ make them understand that the warning is significant
  → ignoring warnings
  → users like convenience.
  → if the security system is unusable, it will be unused.

* Security Economics: security is not free.
  * cost benefit analysis



CSE-405 22/06/2026

Textbook: Introduction to Computer Security by Michael Goodrich, Roberto Tamassia

Part 1: Chapter 1-6.

CIA triad.

Confidentiality Integrity Availability ⟶ 99.9999%.

5 9s

Client — Internet — Server

initiates port tx

iBAS++

8hr 33.33%.

* ping → ICMP pkts
* TTL → decremented at each router, TTL = 0 → pkt dropped there.
* tracert → routers used to reach the dst
  ↳ TTL = 1, 2, ... in a loop.

Security Operations Centre (SOC)

Confidentiality → no part of the comm. should be exposed
mechanism: encryption-decryption ⇒ cryptography

Integrity → ensuring that no tampering takes place. [Man in the Middle]

reason behind cyber attacks ⇒ servers are very old. very ~~fan~~

Vulnerability patched over diff versions

Ⓐ CVE details ⇒ common vulnerability exposures

* DB corruption → due to weak security → data may be changed.

Access:

GPS
Media
Contact list
SMS → expose OTP.

while using the app
only this time → safest.
always

* hence OTPs are not used as much, fingerprints are used.

Simplilearn - Top 10 cyber attacks ⇒ (9) ***

10 case studies

⇒ * each cyber attack has a reason (may be for fun as well)

Lawful Interception → govt can record telecom data. + location

LI

WA → encrypted

NID → important servers

Botnets ⇒ automated attacks can be launched.

1 → Bronze soldier of Tallinn

* akamai.com/ what is a botnet? (9) figure

C2 server → command & control server.

DDOS

Attacker → Bot coordinator → Botnet → Victim → sees attacks from the botnet devices.

not owned by the attacker, but the attacker has access to these by C2 → background commandshell access

illegitimate apps may communicate with c2 servers in the background

CSE-405 22/06/2026

Botnet, DDOS → Attack 10

* How are bots produced?
  - popular website → links → malware
  - popular app → background → ch14: malware.

Trojan → foreground
↳ something else
eg playing chess

* all trojans cannot be detected.
  - through emails → hidden
  - whatsApp
  - chat

Trust violation
↳ common in case of female harassment in BD.

spycam

  - sms link → click
    ↳ camera running in the background
    ↳ livestreaming while online

Android vulnerability

  - sms intercept eg OTP [malware]
    ↳ forward all msg
    ↳ remove the msg
    ↳ stop/ignore the notification

no trace of the breach.

* Google doesn't recommend OTP to the mobile phone.

Yes/No, others

* Banking → big transactions → require fingerprint alongside OTP.
  ↳ biometric authentication must
  ↳ order by BD bank.

Attacks
- Phishing Emails
- Blackout ⇒ powergrid stones and distributes the electricity
  BD ⇒ manual intervention needed → hence no cyber attacks take place

full automated loop needed

iBAS ⇒ hundreds of thousands of transactions per hour

Attack 8

1999 NASA

21 days Shutdown

Backdoor

Email interception (through the backdoor)

if admin's emails can be intercepted

email → used for OTPs / for confirmation.

(BD) new phone → setup by shop owners → email, pwd

OTP received by the shop owners.

⇒ land registration, can neg → everything is online now

↳ not much defense in BD.

Attack 7

Sony Films

Info leaked

stop the release { The Interview

Kim

Sony → music, cinema

↳ South Korea

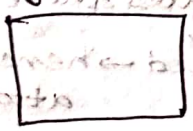
↳ funny interview

top cyber attacks launched by N-Korea

Released all the content → no copyright

piracy ⇒ strict laws in other countries. hard disk format

N-Korea → Cyber Army (State Sponsored)



India, Iran, Russia, China, USA

↳ cyber armies

taken from schools 7-9 years old kids are recruited.

these malwares cannot be defended by anti-malwares.

classes { 5 Linux, shell

6 C/Assembly/Python

7 Reverse Engg/Wireshark

8 Malware, malware dev

Zero-day Attack

↳ all these attacks !
no knowledge about these attacks beforehand.

Attacks

Credit card fraud → on the rise
card stolen → need the OTP as well (BD)
↳ sms access.
remove OTP msg
no notifications.

⇒ OTP is not used in foreign countries ⇒ OTP ⇒ costly
sms charge ⇒ avoided → use alternative

Behavior pattern analysis ⇒ analyze purchase pattern
can verify the new purchase → legitimate or not.
1. different location then usual } behavior analysis.
2. unusual purchase

OTP ⇒ not scalable for mass online transaction.

→ also rate the companies transaction is kept floating
transaction to low rated company → denied
↓
verified with company ratings.

P&B
DBD rating
↳ no such framework in BD
hence confirmation through automated voice calls are used.

Miami → TJMax

Wireless Router

POS machine

2 ways to send the txn to cloud from pos
→ wireless router
⇒ SIM → using data

✗ WEP → almost plain text ⇒ weak encryption in wireless router.
↳ transactions intercepted.
all details available.

WPA

WPA2

WPA3

wireless router access { 192.168.1.1
username
pwd

Attack 5

→ developed from 2004

Stuxnet — 2010 — Siemens

Iran
Nuclear Plant
HIW malware

US + Israeli Intelligence

combination of 5-6 zero day malwares, not a single malware.

knew about the upcoming attacks

Airgap Netk → no wires

all comm^n must be done inside the plant

Email → not feasible.

loaded pendrives left in the surrounding areas.

* human ignorance & hatred → common cyber attack reasons.

Number cloning from internet...
but it called back → it is received by the original number.

Attack 4

WannaCry 2017 May

Ransomware

locked out users & encrypted the data.
↳ ransom for the decryption
↓
must be paid using Bitcoins

SMB vulnerability → Microsoft knew this → not 0 day

Microsoft was working from January

↳ released in march → should have been fixed by April.

Patch

Hackers also noticed the fix released by Microsoft

↳ developed the malware in April ↳ exploited this.

hence nowadays automated updates are done in Windows/Android.

no public release?

chapter 1 more on Vulnerability → next class

27/06/2026

CSE-405

slides /teach/CSE405

Ch-01 Tamassia, Goodrich

9 → from textbook

Security ⇒ who are we defending against (security depends on)

↳ relative to:

* a set of desired properties
* an adversary with specific capabilities

BJIS against North Korean attackers ✗

Military DB vs Indian hackers ✓

cryptography → encryption + decryption.

CIA → confidentiality

- → encryption
- → access control ⇒ honeypot (→ Ch-6) → trap
  - eg. allow access to fake resource.
- → authentication
  - ↓
  - something the user knows — eg. chmod in linux.
    - ↳ pwd
  - something the user has → OTP / radio token
    - ↳ key device → transmission not needed → secure compared to OTP
  - something the user is
    - ↳ biometric

2-step / 3-step auth must.

Android → gmail → Yes / No

eWallet

100,000/= → fingerprint verification

A → B

* authentication system must be fullproof

Secure programming.

fb → OTP → whatsapp

* authorization — Kanth Ch-4

grant select ⇒ not everybody has access to everything in DB.

* physical security

⊛ internal attack ⇒ somebody who was already inside
↳ authorized

Integrity ⇒ data has been altered during transmission

A → B
A → C

100k
↳ 200k

algo — MD5, SHA1, SHA256

library sure

{ backups
checksums
data connecting code

Availability ⇒ info is accessible & modifiable.

↳ physical protection
↳ computational redundancies

DD
↳ submarine cables: 3
↳ redundancy

redundant connections → fallback

AAA
↳ Authenticity → digital signature → not scanned signature
↳ cryptographic computations that allow to commit to the authenticity
↳ Anonymity
↳ Assurance

Nonrepudiation ***
↳ denying something after stating it

withdrawal not possible

eg. sales contract
↳ digital sign [bound by law]

Anonymity ⇒ records/transactions not to be attributable to any individual.

- aggregation ⇒ avg
- mixing ⇒ mix & match reviews
- proxies ⇒
- pseudonyms ⇒ pseudorandom ID

Threats & Attacks

* eavesdropping ⇒ passive attack → only listens, does not modify
* MitM → Man in the middle → active attack → goes through the attacker.
  - ↳ Alteration → integrity violation
* Denial-of-service:
* correlation & traceback
  integration of multiple data sources & information flows.
  - Masquerading

malware
- virus
- worm
- ransomware
- spyware → steals info for investigation

CSE-405 28/06/2026

10 security principles

Internet Usage Policy → violation may have legal consequences
LAN access policy →

* Economy of mechanism ⇒ simplicity in design & implementation.
weird/complex policy → should be avoided
↳ user may not be able to comprehend
↳ usage↓, cost↑

* Fail-safe defaults ⇒ default config should have a conservative protection scheme. → minimum security setup by default.
analogous to physical security for tourists

* Complete mediation ⇒ access to resource must be checked for compliance.
users
Teller
Asst Manager
Manager
GM
CTO
2nd officer →
→ security/compliance policy for access
⇒ external security audit → assess access compliance
Maker / Checker ⇒ must ensure consistent txn
write access / approval

* Open design ⇒ security architecture & design should be made publicly available. → DES
security by obscurity → private protocol → eg: BD Military
open → algo is open, keys are secrets ↳ algo & keys are kept secret.
↳ for scrutiny by researchers.
TCP/IP
SWIFT ⇒ intl sw used by banks for intl txn
BD bank atk ⇒ malware atk on the swift system
↳ private
both open & closed design have advantages.
VS Army → closed design, BUET → ~~close~~ open
policy usage depends on the usecase

* Separation of privilege ⇒ multiple conditions should be required to achieve access to restricted resources on have a program perform some action → for sensitive resource

File server
(DB) access.

29/06/2026

* Least privilege ⇒ system should operate with the bare minimum privileges necessary to function properly.
→ if needed grant privilege temporarily

grant privilege
revoke "

Ubuntu
bobo@CSE> sudo mkdir /usr/bin/test → normally do not have access to this directory.
root user does not exist
if needed go to root & return to low privilege
for command execution
else may delete directories/files unintentionally

root@CSE # rm -vfr
/ → root folder
. → all
-f need

need-to-know basis → military/police concept → special branch
↳ don't inform unless necessary.

* Least common mechanism ⇒ mechanisms allowing resources to be shared by more than one user should be minimized

Secret doc
M1 → Alice
M2 → Bob

same access mechanism
↳ cannot detect source of changes

separate mechanism
↳ detectable
↳ locks

eg. recording entrance point

one admin → single point of failure
↳ may be sick / may betray / may leave
↳ cannot do this

* Psychological acceptability ⇒ should be well designed & intuitive
↳ should adhere to what the user might expect.

data center raised floor ⇒ wires, air circulation
racks, cold aisle, hot aisle
precision air ~~cooling~~ (PAC)
conditioning
↳ (2 units) operate alternately 8 hr, 8 hr.
may be (3) ⇒ backup.

* Work factor ⇒ cost of circumventing a security mechanism should be compared with the resources of an attacker when designing a security scheme.
corresponding ~~logs~~ logs should be employed

security should not be over-powered

* Compromise recording ⇒ logging server ⇒ for incidents
↳ record the details of an intrusion
not all logs are of use
sensitive ongs monitor routinely (proactive)

⇔ passive record
active monitoring
AI monitoring

⇒ org should decide how much recording will be done.
how long should the records be stored.
enough storage is needed
log server
↳ storage ↑ cost ↑
policy

SSD
6 TB
1 month

TIN
BIN → business
VAT ID

after 9/11 ⇒ govt instructed telecoms to log intl calls

Access Control

matrix ⇒ Access control Matrix ①

linux file system / windows

backup ⇒ system user
normal user → cannot see /admin/

file permissions are managed this way

rwx → x

Access Control List ②

each folder / file has a list of access for every user.

lists = # dirs / files

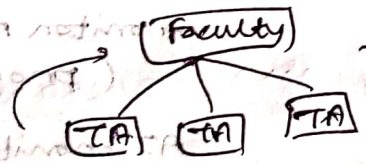
↳ user wise ⇒ user → list ⇒ **capabilities** ③

chmod → change access
chown → change ownership
actual owner can transfer
root can transfer for all.

Role-based Access control

* define roles, not individual list

super-server



Manager → 1400
create one role

easier { new manager → assign the role (grant)
left → revoke.

change designation ⇒ change role

Actual system → always role-based grant-revoke.

Symmetric cryptosystems (3DES / DES / AES)

encryption & decryption keys are the same

comparison → different ⇒ asymmetric

comparison

gmail server

let 2 billion accounts ⇒ as many keys are needed

2B

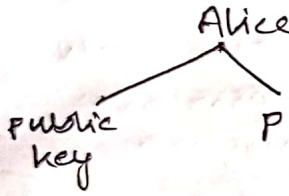
(Symmetric) → disadvantageous

weak in combination

K1 is shared b/w user 1 & gmail.

K2 " " " " 2 & "

public key cryptography ⇒ (RSA) (Asymmetric)



2 keys

only 2 keys compared to 2B

stronger than symmetric

n = 100

A 99 keys to talk

n-1 to others

$^{100}C_2$ =

$\frac{n(n-1)}{2}$ ⇒ shared by all.

keys in symmetric = $^{n}C_2$

keys in RSA = $2n$

everybody has to know only 2 keys

Storing passwords

store in plain text → admin can see this.

strong pwd

upper case

lower case

special char

num

upper/lower c^{52}

num. 62^4

special $(62+32)^4 = 94^4$

ASCII 128^4

4 char pwd

banks prev ⇒ 8 chars

now ⇒ 10

Password Aging = 60 days

automatically expire

regular change ⇒ hacker has 60 days to ~~extract the pwd~~

$60 \times 24 \times 3600$ sec

Q on pwd

exhaustive search ⇒ cannot try at such a high rate

Wrong pwd

3/4/5 trials ⇒ lock ⇒ harmful for user

↳ suspend for 5 minutes.

5 password → 5 min → cannot try out all pwds in user's lifetime

220

230

video + ~~pwd~~ slide

CSE-405 04/07/2026

Chapter 2: Physical Security → 1st security stage

Physically protect the asset, e.g. server room. ⇒ important

(2.2) Locks & Keys

side-channel attack
↳ direct physical access
Man-In-the-Middle
eg. through switch

noise interference

generate signal from outside to corrupt the data in the hard disk

or spy
or physically copy the data.

or laser beam
↳ also damages body cells → physical damage

hence, many data centers have laser proof walls, not glass doors.

may restrict high-rise construction in the surrounding areas.

Compliance

white space ⇒ open fields/ponds surround the center
→ fence outside the ponds with electricity flow.

⇒ Most locks can be easily compromised.

⇒ Yale Pin Tumbler Lock → (3X)

case, plug, keyway
spring, driven pin, key pin
shearline ⇒ pins need to be aligned with the shear line to rotate

Master key → master pin

price of the lock must be reasonable considering the asset.

⇒ Tubular lock

(2.3) Authentication Technologies → detailed

Authentication single technique → not used
pwd + OTP + biometric

Bar-code → not for security, fast need
save time during checkout
else writing the name would be necessary.
↳ 2D bar code (2.3)
↳ boarding pass

QR code
↳ 2D, machine-readable barcode
↳ not an encryption, can be reversed
eg. with pwd.
Bangla QR code

Bar code vs QR code → may be used in place of business cards.
8-20 chars upto 4296 chars

QR code works even if 30% of it is damaged.
↳ higher resilience.

Magnetic Stripe card
magnetic card reader → can easily steal info
can clone the cards ⇒ (easy)

Smart card → encrypted, has chip inside.
↳ difficult to duplicate.

GSM network
Base Transceiver Station (BTS)

telecom standard algo
- A5 encryption algo
- Authentication A3

A3

need to authenticate w/ the tower.
cannot use the tower otherwise.

SIM → 01711...

IMSI → international mobile subscriber identity
not the mobile number

stored against the number

K = 128-bit this key is written onto the SIM.

stored against IMSI

45312

key is only known to the telecom server & SIM.

turn on mobile → beacon → send IMSI to tower
tower sends back a time dependent random number R 128-bit

R = 20025
A3
K = 45312
encrypt

encrypt R using K and A3 algo & send to the tower
tower also performs the calc.
match → authenticated

encryption → A5 → X

normally
can tap in

RFID
radio frequency identification.
RFID reader → track / prevent stealing.

Attendance system → fingerprint better than RFID

radio signal → not necessary to be in line of sight
wireless routers also use this, walls are not a problem.

RFID applications

bills are sent later on

* can key fobs
* electronic toll transponders

Biometrics

must keep alternative ⇒ compliance

↳ digital lock

sometimes fingerprints may not match / voice
eg in winter.
use PINs as alternates

requirements

* universality ⇒ almost every person should have the characteristic
* distinctiveness ⇒ should be separate / unique
* permanence ⇒ should not change over time
* collectability ⇒ effectively determine & quantify

iris pattern → not easy to collect
same goes for DNA.

security & privacy concerns

↳ one-time biometric leak → compromised forever
↳ reveals private information

walking / body movement signature ⇒ one kind of biometric.
pattern

CSE-405 05/07/2026

Security concerns

fingerprint leak → may replicate using extra layer
↳ framing

assurance ⇒ citizen privacy policy → how much data can the govt. collect & store?
↳ BD → no such policy

Telecom ⇒ system admin → full access to customers' biometric data

pwd protected file ⇒ can be broken using brute force

Forensic workstation ⇒ 50L+ Tk.
↳ can break pwds in 30mins-1 hr.

(2.4) Direct Attacks → manual attack → BD → most cyber attacks are caused by humans. (not computer based)

- Eavesdropping
- Exhaustive Attack → trying all pwds → system does not allow this
- Gaze Attack → shoulder surfing → read info over shoulder of the victim.

combine exhaustive & direct

- Signal emanations ⇒ screens emit RF
  capture these to detect what is being displayed.
  ↳ visible light reflection ⇒ manual atk

surveillance → may be privacy violation (for customers)

- Acoustic Emissions ⇒ keystroke recording → distinct sounds ⇒ ML model.
- Hardware keyloggers ⇒ connected both USB port of computer & the USB cable coming from a keyboard.

need 2FA

developers should secure the login → email about suspicious devices.
ID series.

secure login
warn about suspicious login.

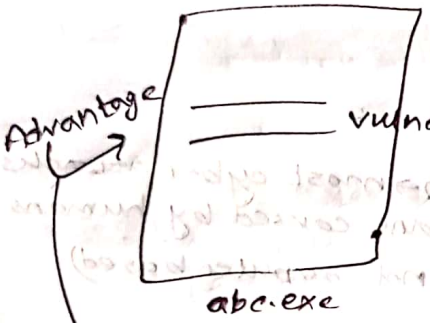
anomaly detection

(no OTP)

- geolocation mismatch
- purchase pattern mismatch
- high value

Ch-03: Buffer Overflow Attacks

Exploit ⇒ any input that takes advantage of a bug..



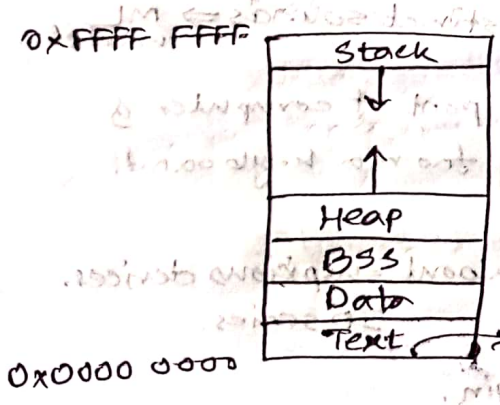
find vulnerability
reverse engineer the program
↳ decompile
build the exploit

not attack tool
Exploit → applied on

Ch-03: OS → pant → skip

Ch-05: Network → TCP/IP → skip

Unix Address Space



text ⇒ machine code
data ⇒ static program vars initialized in the src
BSS ⇒ blocks started by symbol
↳ uninitialized vars (static)

heap
stack
} interest

dynamic memory
malloc → heap.

(c) ⇒ operating system vulnerability

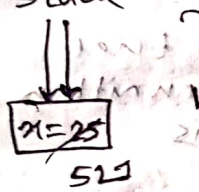
printer / scanner driver → written in Assembly.

(*) what was the main vulnerability of BD bank attack?

Buffer Overflow ⇒ runtime → user i/p

compile time ✗

on allocate heap to attack stack



overwrite the variable

int num[25]

25 521 → accesses other position in memory → garbage.

for (i<n)

Stack smashing attack

Heap

main(int argc, char* argv[]) {

char var1[15];

char cmd[20];

strcpy(command, "whois");

~~strcpy(var1, argv[1]);~~

~~strcpy(var1,~~

strcat(command, argv[1]);

strcpy(var1, argv[1]);

printf(var1);

system(command); ⇒ execute

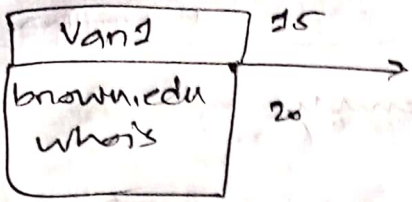
}

whois

↳ pulls info about domain

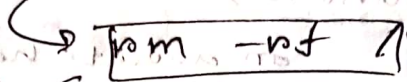
command = "whois brown.edu"

scanf("%s", var1);



user input.

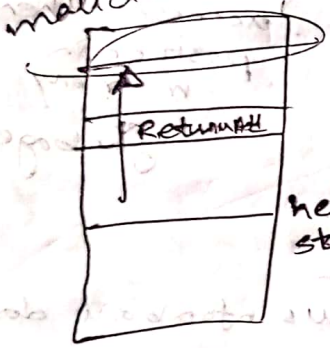
35 characters input
overwrites command



design the i/p such that command is overwritten like this

or use cmd → runs powershell.

malicious.



Return Address Smashing

overwrite the return address
↳ jumps to malicious code

using buffer overflow
overwrite other func

no vulnerability → hashing → naming
race time attack

safe, unsafe func

scanf → unsafe
strcpy → does not check
better → strncpy → checks the size, need to place '\0' manually.

unsafe func → code will have buffer overflow vulnerability
may be exploited.

Shellcode Injection

04/07/2026

Software / Web App / Apk

OS / Desktop

attacker perspective

↳ find vulnerability

vulnerability assessment is not the same as attacking

Not in syllabus

Vulnerability Assessment Tool

assess web app / doc / ...

free / paid options

orgs like BRAC bank regularly assess their web apps.

CVE

Cvdetails

↳ publishes the vulnerabilities

↳ lists all old vulnerabilities

Dev

SW team

- SW Testing team

- Load & security testing team

↳ tools

↓

open-source

↳ not that good.

Jmeter

Apache server → URL → assess vulnerability

⇒ find the existing vulnerabilities

⇒ exploitation tool → basically virus!

reverse engineer

vulnerability

File Upload / RCE / Sql Injection / XSS / CSRF ← assessment tools check these / attempt these

↳ remote code execution

↳ continuous file upload

sql injection attack

UserId : 105 OR 1=1

SQL vulnerability → if this attack is possible
attack takes place → SQL Attack

Honey Pot
↳ trap

Buffer overflow
return address smashing
Malicious
↳ shell code

OS vulnerability needed

privilege escalation

Admin
↑
Tom

no prevention in this mode.

popular command
↳ **setuid** → how?

ls -l
shows 9 permissions

rwx rwx rwx
rwS r-x
↑
difference

admin (OS)
kernel running
user running tom

fopen(- -)

when executing fopen in kernel, execute malicious code
↳ has privilege issue

easiest → modify library files
DLL

process privilege → same as the current user.

setuid → used to temporarily grant a user the file system permissions of the executable owner.

/bin/ls → owner=root

Tom → ls -l / → root partition.
↳ this should deny

ls -l /root
ls -l /home/Bob/
} these won't be allowed

Tom → password ← ⇒ changing Tom's pwd.

pwd command in /bin → modified in etc shadow & etc password file
owner=root

rws

/etc/password
↳ Tom doesn't have the privilege to modify these needs root permissions even if Tom is running

rws allows this

privilege escalation

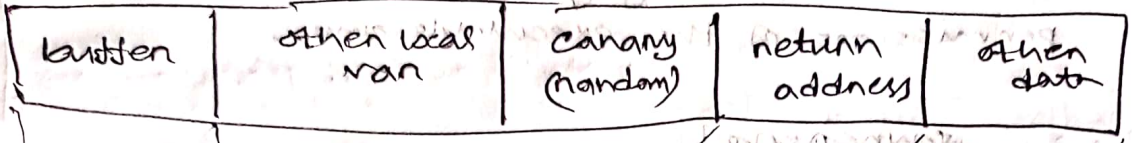
user → kernel

setuid → misused for privilege escalation

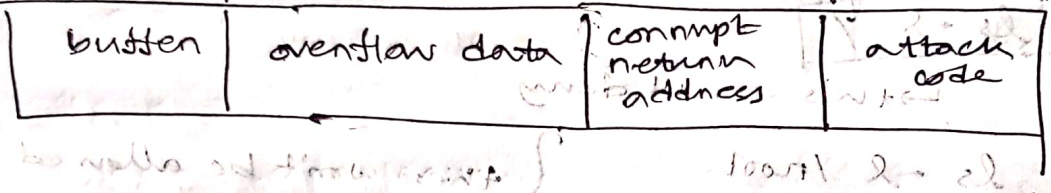
Q2
* what does setuid do? how privilege escalation is done using setuid? show with examples?
* why privilege escalation is needed?

Stack-based buffer overflow

normal



buffer overflow attempt



random number pushed in front of return addr.
↳ if this value changes while returning
↳ stack has been manipulated using buffer overflow.

cat & mouse game

hacker may keep the canary intact & change the return addr

CT

BO bank attack

video + ch-1 + auth + overflow

slide

physical

textbook + class

printer driven manipulation

Lowest class

CSE-405 11/07/2026

Operating Systems Security

3.1 ⇒ covered in OS ⇒ no questions from here.

revise
- commands
  - ps
  - top
  - chmod
  - chown → change ownership

tom → to someone
root → anyone to anyone.

systemcall ⇒ user running
switch
- syscall = fopen(..) ← manipulate this code → malicious code running with kernel privilege
- kernel

DLL → corrupt → run in kernel mode
↳ runs with kernel privileges

syscall → manipulation ⇒ easy to perform permission escalation.

print via printer → via kernel
keyboard to screen → via kernel

Q ⇒ BD bank attack ⇒ describe

printer Driver manipulator

machine → switch → Printer → mined → changed the printer driven

not networked comm

printed copies are generated for trx

6:00 → closing → people leaving

Thursday

printer → malfunction
↳ no tax record

off 3 days
- Fri
- sat → realized manipulated printer → contact USA
  ↳ off
- sun → USA/Europe → off day

↳ tax → money sent to Philippines → collect from there.
↳ casino.

process

↳ instance of a program

malicious threads → threads may run in the bg

some threads are tied to the parent → killed with parent process
↳ some are independent

malware generation using legitimate process.

↳ used in hacking running in bg

target → popular OS & devices, apps

top command → top -a → display top CPU processes.
↳ unknown source → suspect.
↳ unknown sw.

file permission

(s)
↳ setuid
↳ file owner: root
↳ other user wants to execute with owner's privilege

normally have access
↳ execute in current user privilege

(s) → root

(9) how to do privilege escalation with setuid? Discuss with an example.

drwx /bin/ → directory.

↳ what does this mean?

↳ permission to go inside the directory.

can run cd

else cannot use cd.

↳ permission denied

inode content read → read permission

execute ⇒ traversal permission

directory →

VM

↳ 2 types

↳ HW level → diff OS → Type-I VM Hardware VM

↳ hosted VM → on the existing OS

↳ copies of mem

Type-1 VM → better for working → full RAM access.

all banks run VMs → multiple OS

(3.2) OS Security

boot sequence ⇒ security breach scope for

↳ not used now.

↳ change → CD-ROM, HDD, Network, USB, pendrive

bring USB to the top.

↳ w/o pwd can access the hard disk.

↳ can copy files from the FS w/o the machine's pwd.

→ do not need to go to the machine physically.

Hand disk encryption ⇒ to prevent attackers from removing HDD & using.

↳ windows built-in → bitlocker

locked → encrypted
unlock → decryption
booting time ↑

⇒ can use additional encryption as well.

Security vs Usability

security ↑ usability ↓

Hibernation

closes the laptop → hibernation

⇒ copies current status of all running process in hibernfil.sys → to nonvolatile memory.

write before going to standby

resume → battery remaining → resume proc

get hibernfil.sys ⇒ info about process

↳ Computer forensic ⇒ used by police.

Mobile forensic kit ⇒ bypass mobile pattern / locks

credit/debit card ⇒ reversed PIN → contacts police

Event logging

keep track of what procs are running.

OS security log ⇒ logs wrong attempts in windows security log

↳ bg log.

just logging is not enough

windows security log

→ another system → read the log

↳ 3 repeated wrong attempt

↳ alert admin

proactive analysis

→ may use agentic AI for behavior analysis

→ may shutdown the access temporarily → (i)

→ contact actual owner → (ii)

→ msg system admin → (iii) (pwd attk)

Pwd security

user: Alice

password: [2]

Dictionary → file of pwds.

500000 → pwds

dictionary attk

hackers generally publish the pwds only, not the user

→ available online leaked pwd.

↳ check for pwd in this file.

pwd: BUET1234$

DB

Alice → hash(BUET1234$)

self-study

relation both these

/etc/pwd → only basic info → does not have the pwd ↳ x is written

/etc/shadow → contains the pwd.

↳ dump this → access to pwd hashes

relation

Rainbow table → for hash reversal.

↳ online tool/API

⇒ why is rainbow table used? functionality.

Password salt

random number with each user id.
salt

	salt
Alice →	9812A1 —
Bob →	1245 ..

("BUET1234$11 9812A1 —)

⇒ hash(pwd+salt) → store this in the shadow file.

$2^{32} \times 500k$ → possible combinations.
salt 32 bit

10 digit char
Gold
↳ 94^{10} pwd
difficult to breach.

⇒ rainbow → direct pwd hash
↳ does not have salted pwd hash.

breach salt → must store in highly secure DB.

CSE-405 12/03/2026

Access control list DAC

Alice

a.txt b.txt c.jpg chmod otw a.txt ls -la

closed vs open → default → allow
↳ explicitly deny
↳ default deny → trust none
↳ ~~explicit~~ explicitly allow

Linux
↳ default deny → most used
allow any ACE → access control entry
most infrastructure servers → Linux

Windows
allow & deny ACE

file access
/dev/ devices
/mnt/ mounted
} all are files

2 ways to create shortcuts/ links:

link cmd ln
↳ hard link
↳ soft link → like shortcut
↳ remove eg file
↳ shortcut stays but is invalidated
symlink
symbolic

/home/alice/a.txt
2 hard links point-
remove all hard links
↳ that file will be deleted from that location

multiple hard/ soft links can be created for any file.

ls -l

-rw-r-- ---

group → read only

others → none

d rwx → directory.

-r--r--r--

444

-rwxrwxrwx

777

special permission bits

- set-user-ID → privilege escalation: Causes executables to run as the file owner regardless of who runs it.
- set-group-ID
- sticky-bit

-rwS

rwS → user

r-S → group

-rwS r-- r-- → user: Alice, owner: root

/bin/passwd

executable file passwd

utility time to change pwd.

alice@CSE$ passwd

↓

alice is trying to change her pwd but the owner is root

runs with the privilege of root

why? ⇒ may be misused

next page.

/etc/passwd text file → owner root

password actually in shadow file

alice: "BUET123" → change "Dhaka12"

who setuid → Alice cannot access this restricted file.

sensitive file → /etc/passwd, /etc/shadow } Alice cannot change her own pwd then who root privilege

set-group-id → sgid/setgid

↳ run

⑧ ⇒ both → what happens?

group

alice → student

group ID

rws r-s r-- /bin/passwd root admin

↑

despite Alice being in the student group.

match with file group id → privilege escalation

file's group instead of the user's group.

rws r-- r--

4744 744 rwx

rws r s r--

how to turn both on?

6744

octal

2744

2 → group

sticky bit ⇒ dir ⇒ prevents users from deleting/renaming files they do not own.

↳ may allow to write

↳ direct stop write → write → ✗

↳ delete ✗

a.txt alice rw- rw-

alice student-
bob student-

GUI

can Bob access Alice's file?

drwxrwxrwt

6744 → setuid+setgid
7744 → setuid, setgid, sticky

sudo su → attempt to be superuser
su → asks for pwd.

sudo su - ⇒ logs in as root, changes the prompt

sudo su

alice@CSE/home/alice $ su
root@CSE/home/alice $

su -

root home dir would be here

system administration & ownership

chmod
chown
chgrp → change group.

-R → changes recursively.

chown -R root dir1 → dir1 & everything in it → owned by root

chmod go+rwx -

slide 27

HW

next day → Malware.

CSE-405 13/07/2026

Ch-04: Malware

propagator { virus → human-assisted propagation
worm → automatic propagation

concealment { rootkit → dangerous → modifies OS processes to hide its existence, eg. ls
trojan → provides desirable functionality but hides malicious--
↳ does both good & bad.

Insider attack

↳ dangerous → has internal info, IP secrets.--
↳ major attks

Backdoors/trapdoor ⇒ no alarms generated by firewall, ∴
frontdoor ⇒ has many security measures.

⇒ some user has been created → nobody is aware of this
Sony (admin) → background
↳ privilege
admin admin → actual admin

Non-malicious backdoors → may be for fun/debugging purpose
↳ forgot to remove msg.
↳ eg. shortcut keys
↳ Easter eggs

Malicious backdoors ⇒ reverse tunnel
outside to inside → tough due to firewalls
inside machine to outside control & command center

Logic bomb → omega engg logic bomb.
↳ lock/damage sw using logic

→ user 12345
(fix.exe)
↳ actually deletes contents of F drive

code review
dev → senior dev → manager
↳ hierarchy is necessary

wiped out the HR/ERP sw
↳ contained all the data & sw
↳ purge → wrote 0 on all the data → not recoverable using forensic.

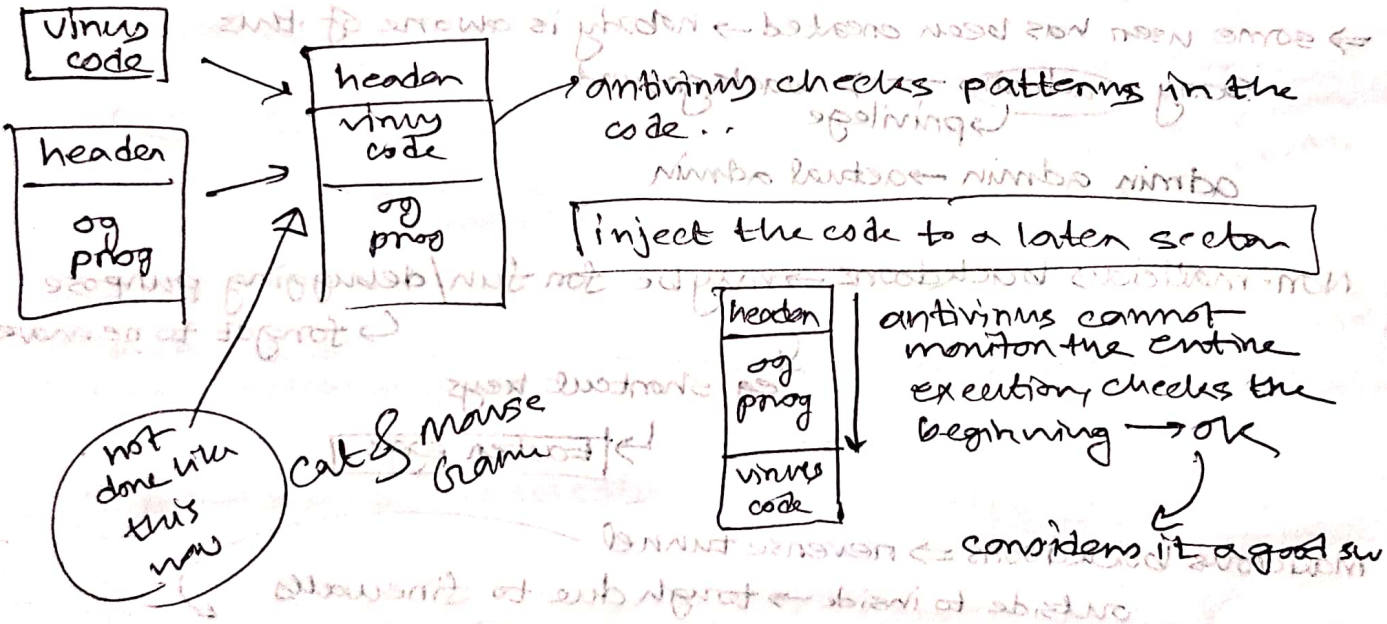
defenses against insider attacks

* avoid single point of failure
* use code walk-throughs
* monitor employee behavior.
* physically secure critical systems
* access control

normally logic bombs are locked onto some special date
↳ lock the functionality
↳ may be valid. limited sw use contract.
full sw delivery
↳ should not have logic bombs (lockouts)

virus
↳ human assistance needed
↳ replicates.

Injecting virus code ⇒ may push virus code to multiple location.



may segment virus code into multiple places.
↳ with legitimate code eg. calculation.

Virus phases → does not attack immediately

* dormant → low laying
* propagation → replicate, infect
* triggering → activation mechanism. → maybe specific date or smthing
  - ↳ different triggering mechanisms
  - sensitive payloads check many conditions.
  - eg. StuxNet
    - ↳ checks its location before starting malicious activity
    - → specifically location-based. won't triggen elsewhere
* action → payload.
  - eg. encrypt / export / leak file.
  - malicious
    - financial factors
      - ↳ may do nothing → do something funny display ads.
      - → may damage HW devices.

virus techniques

macro viruses → macro → auto executing code. → may cause damage

macro in excel / word → warning when downloading.

stealth techniques ⇒ all viruses use stealth techniques. avoid the defense system.

Defence system

malware ⇒ it has to avoid detection

Malware creators → buy → Latest firewall, latest anti-virus → check whether their virus gets detected

detection → sends signature to the cloud. → why?

Detection → MS cloud — Microsoft Defender

↳ Threat Intelligence / Intel

security company { MS, Checkpoint, Palo Alto } have threat intel.

malware developer ⇒ does not want to send signature during testing.

EDM → keeps the network connectivity down

cat & mouse → FW/ Defender ⇒ may locally store & send later

isolated pc → never connect to the Internet → push updates using pendrives to the isolated pc

download

rootkit → uses stealth kit

point2point

P2P Network eg Torrent

↳ easy to insert an infected file.

not much info about the server.

add malwares to the audio/video files.

usage ⇒ punishable offense.

serve more with malware

Paid software

repackaged → Free software (malware)

search malware signature

website → has list of known malwares.

virustotal

↳ free

others → paid

Mutation ⇒ malware → Mal.exe hash = 1AB2...

known malware → hash known worldwide

some change	Mal.exe	Hx = 1AB2	
	Mal1.exe	H1	new signatures
	Mal2.exe	H2	
	Mal50.exe	H50	

eg. corona virus → Adapt

different mutations of the original malware

↳ so antivirus sw cannot detect it with original hash.

⇒ malware, adware

sometimes users select to view ads rather than paying ..

Malware functionality

slide 20

* adware
* browser hijackers
* trojan downloaders
* dialers
* key loggers.

drive-by downloads

18/07/2026

Virus

injects the virus code to some program
↳ split into blocks ⇒ tough to detect

⑨ ⇒ do not inject to the beginning ⇒ anti-virus s/w scans the starting portion of the executable.

why?

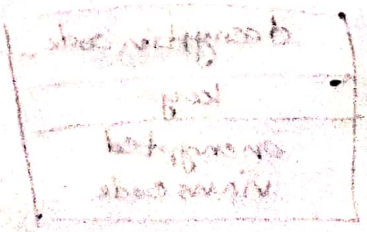
Phases

* dormant → lays low, avoids detection
* propagation → replicate, infect
* triggering/activation ⇒ (triggering) → some condition.
* action

virus techniques ⇒ (textbook) → patterns

macro virus ⇒ attached to ms word/excel → warning when opening ⇒
↳ (active ☐)

stealth ⇒



P2P networks

↳ used to spread viruses

eg. torrent, streams

active file → audio, video.

↳ easy to attach malwares

crack sw → run using admin privilege

may use

* Mutation.

* propagation via websites → popular content

* adware

* browser hijacker

* trojan downloader → not a malware, but downloads malwares.

Drive-by downloads

↳ inline js.

Concealment

- encrypted virus ⇒ virus wants to hide itself
- polymorphic virus
- metamorphic virus

encrypted virus

plain code → detectable from the machine code

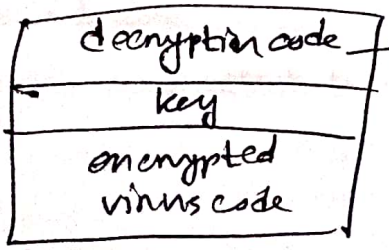
machine code → cannot understand.

need the decryption key as well.

use figs in exam

points/steps

3 things



→ decryption engine.

insert at the start
↳ antivirus suspects at the decryption code
↳ try decrypting → encrypted code → detected.

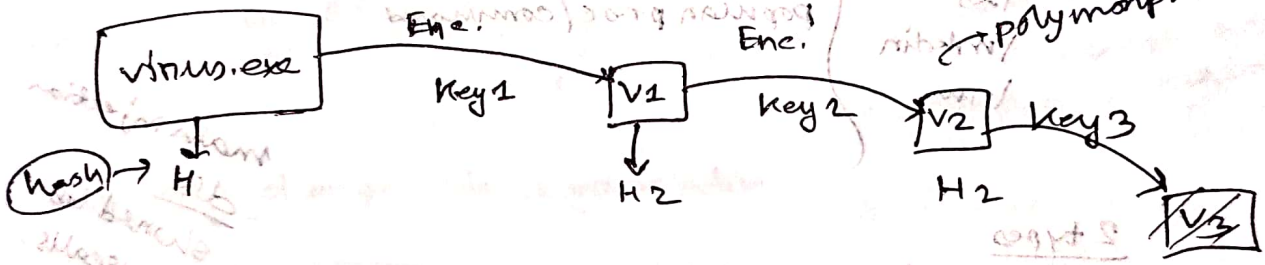
⇒ soln ⇒ hackers send the key via a diff. channel.

* some antivirus may detect only based on the decryption code

RCE → vulnerability
↳ remote code execution/ injection

Polymorphic viruses

constantly create new random encryptions of the same virus body.



⇒ spread V3 ⇒ cannot detect that V3 was originally V.

who key, decryption engine

⊛ somehow separate V3.exe

MAT → malware Analysis Team

detection by emulation

have 100 known og viruses → loop → for all simulate the steps & try to detect

unknown key
↳ need to enumerate

find the original virus

time-consuming

may be custom encryption algo.

check

Stuxnet code Analysis

first level of defense → soc

depth → MRT / sandboxing team

Sandboxing → testing malware on our device is risky
- test in a sandboxed env
  - ↳ VM → sandbox within vm
- expensive s/w
- looks

Anti-virus technologies

* simple scanners.
  - ↳ look for signatures

\bin\ps
\ls
\mkdir
\rm

popular proc / commands

HD

2 types
- → manipulate Hard drive copy
- → " RAM copy → when loading

main injection

dll → shared lib.

syscalls.

original file → hash in the cloud of the distributer
- OS checks all the file signatures when booting.
  - ↳ mismatch ⇒ integrity violation

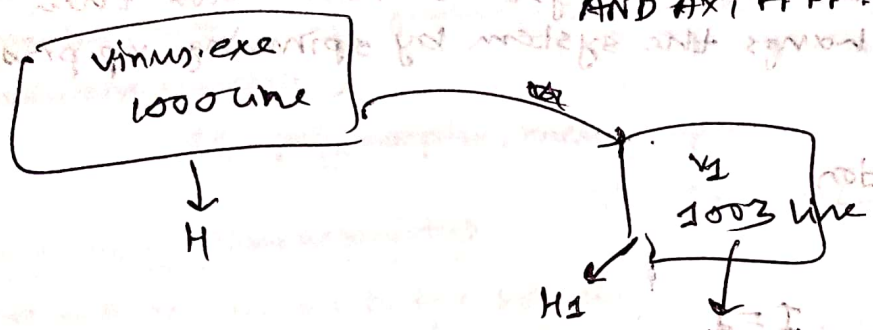
better to detect, easier

* hence hackers do not try to do anything during booting.

Metamorphic viruses

deliberately push some useless code within the virus

AND AX, FFFF ... MOV AH, 0 → no change
CLS AH → change

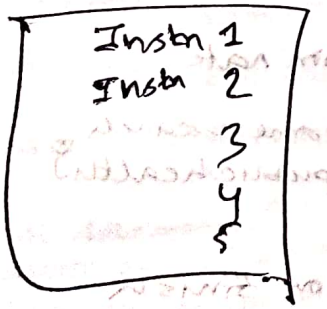


H180

mutation s/w ⇒ src code → mutate

* count in CX
  use BX in loop
  } change neg
  ↳ machine code changes
  ↳ loop code change
  ↳ hash doesn't match.

* may change code organization



Worms ⇒ viruses vs worms
↳ automatic propagation
↳ via code

need human intervention

Morris Worm → research purpose

↳ not harmful, just started procs

not multicore systems back then

↳ hangs the system by spinning up processes.

Worm propagation

$N = 100$

infected → $I(t) = 0$

susceptible → $S(t) = 100$

$I = 1$

$S = 99$

time dependent

study → code Red → exam → ✗

any virus will work only in the first few days!

↳ Later → FW will block.

propagation: theory

$I(t) + S(t) = N$

$dI/dt = \beta I(t) S(t)$ → infection rate

β ↓ constant

↳ from some research publichealth

slow start → fast spread → slow finish

middle ground → infection rate ↑

$I = 50$

$S = 50$

38?

Signature-based defenses don't help

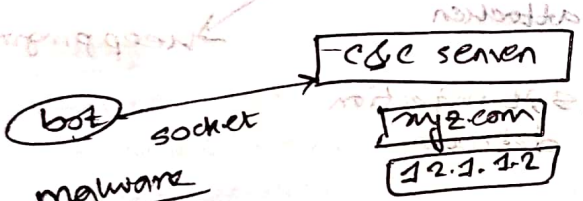
new infection
Zero-day attack
malware mutation
} signatures don't match
↳ eg. polymorphic, metamorphic

Storm worm characteristics

⇒ worms connect to the botnet
⇒ get instructions from C2

chatbot → phishing links

C&C server command & control



if these are fixed
↳ easy to detect via decompilation.

malware
↓
Decompile
↳ check socket conn addn.

dynamic ⇒ tough

obfuscated code ⇒ cannot find the url & ip via decompilation

anti-debugging..

* Botnet → collection of compromised hosts.

↳ remote shell opened → use the machine to perform multiple tasks.

⇒ crypto mining, DDOS, phishing, keylogging.

Botnet Monitor: Honeypot spy

Internet → Server

appears as a legitimate server but is actually a Honeypot

if the attacker attempts to access the machine, trap the attacker.

→ keep pinging

CSRF, SQL injection detection...

also monitor sources of attks. -

normally used

Passive monitoring ⇒ logs all the network traffic.

logging → check after any incident occurs.

active monitoring ⇒ false positive alerts } AI based agentic monitoring

more attks. → AI based atty defense must use AI as well.

Future gen of Botnets

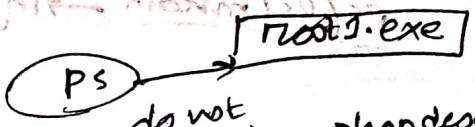
* polymorphism → changes the url, ip, code frequently.

↳ cannot track the traffic.

Rootkit ⇒ tough to get rid of

↳ hides behind the OS → background of OS.
↳ very hard to detect

replaces core system utilities → ls, ps. -
⇒ hides itself from the results



→ manipulates the OS utilities & data structures
↳ page table, proc table, file table...

+dll (.dll) → system dll files → also manipulates
↳ OS depends on these

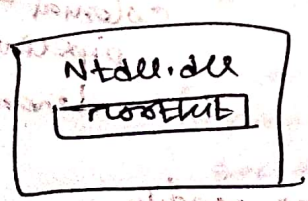
cloaking

↳ user-mode API filtering
↳ kernel-mode API
↳ kernel-mode DS manipulation
↳ process hijacking

undetectable

electronic warfare ⇒ DDoS atk on the radars
↳ cannot detect jets, low-flying drones (not visible to radars & satellite systems)

user-mode API filtering



malware exists
proc exists & is running
} but does not get listed
↳ hardcoded.

detects something

user-mode rootkit → easily detectable → RT detect, NT detect

kernel-mode rootkit ⇒ high privilege

function hooking

ps/ls/mkdir → injects itself within these.

dealing with rootkits ⇒ reformat OS

→ cannot detect

→ but perf degrades. → need benchmarking

reformat OS ⇒ if the data is the src →

- CPU 80%
- usual 60%
- high network activity
- process response time

Trojan Horses

appears to be a legitimate s/w ⇓ does something useful

↳ malware → appears to perform some useful tasks.

→ does both the actual task & malicious tasks

↳ malicious activities in the background

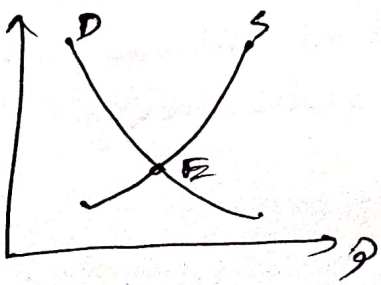
eg. key logging, system breach/info leak (if admin access is granted)

trojan downloaders → not a trojan itself.

* AIDS trojan → floppy disk ⇒ how to . . . → ransomware (encrypt data)
* False Internet Explorer upgrade → exe file

MS → colonial pipeline ↳ ransom

Economics of Malware



malwares are readily available nowadays.

Adware ⇒ continuously requests advertisements from adware agent

not really malware ↑

advertisement agent

⇒ many pop-ups / ads

20/07/2026

~~Adware~~ marketing policy → instill fear in the user

"click the link ... to extend your quota"

fake antivirus → eg. free trial, warns about some imaginary malware

orifice → opens backdoor

privacy violation, ransomware, business secret → sell to competitors.

malware economy → building on arden.

↳ loss of trust among customers.

→ sometimes the source code for old malwares are made public

↳ new hackers can use these.

open web → both defense & attack → both sides have the public info.

Adware ⇒ victim computer ⇒ requests ads from ad company.

↳ normally 1 ad

↳ calls in loop ⇒ repeated ads → disrupts actual work

* spyware → audio/video/screen capture/recording, key logging, web history

privacy violation
reputational loss
social loss

countermeasure

- signature-based approach → pattern matching
  - still the dominant approach.
- ① new malware → detected by FW/agent almost immediately
  - FW → threat intelligence → sent to HQ
  - If the company has worldwide business
    - captures the close signatures
    - same malware can't attack everywhere
- ② signature database/threat intel DB is synchronized rapidly → within seconds → all over the world.
- ③ OS → hash → actual version → compare with the version in RAM → corrupted.

→ sign → doesn't work for zero day malware

binary file → ② types of analysis

heuristic
- decompile → code, string
- ① static analysis → not runs
  - behavior, activities
  - eg: running program files, modifying OS code

like bomb disposal unit

popular

② dynamic analysis → let the malware run
- in some isolated env → sandbox
- monitor behavior

online vs offline antivirus s/w

- not used now

prev → some machines → never connected to the Internet

distribution → sync the threat intel regularly

hash table → online updates ..

Quarantine

suspicious file → isolate → prevent explosion
↳ not sure ↳ analyze in sandbox env
may

Ch-05: Network Security

normally data centers use various security products

security products
① layer 7 FW → Next Gen FW
② NAC → network access control?
↳ identifies which laptop/device belongs to the network
has list of valid computers
↳ random devices can't use

content injection XSS CSRF;

↳ ③ ESA → email security gateway/appliance
④ WSA → web " " "
⑤ VPN-enabled router ⇒ VPN
small bank → Head office last router
↓
VPN enabled router
↔ some small office in some remote area → router

to avoid eavesdropping
encryption/decryption
↳ separate router/software on NIC card

Network forensics → one of the best tools ⇒ Wireshark.

MAC, ARP, IP → bits
↳ burnt into NIC card → prev assumption
↳ can be changed actually

ARP → MAC determination against IP

reply ⇒ MAC address.

first msg → broadcast → request

next → unicast → reply

ARP table ⇒ arp -a

problem: who replied?

⇒ anyone can reply } cannot confirm

↳ not detectable

↳ ARP spoofing atk

A → B

← ✗ replying

very common atk

cond^n ↳ hacker is in the LAN

↳ replying on behalf of some machine (may be non-existent)

⊛ no request sent, still accepts reply

⇒ ~~gratuitous ARP~~ → gratuitous arp reply

problematic → updates the table

↳ poisonous reply

special? LAN, TCP/IP → assuming nobody is malicious

Man-in-the-middle → easy using ARP spoofing

~~take~~ poisonous table

↳ pkt to hacker

↳ hacker fwd to actual receiver

↳ both way.

Defending ARP Spoofing → mostly switch can take the actions.

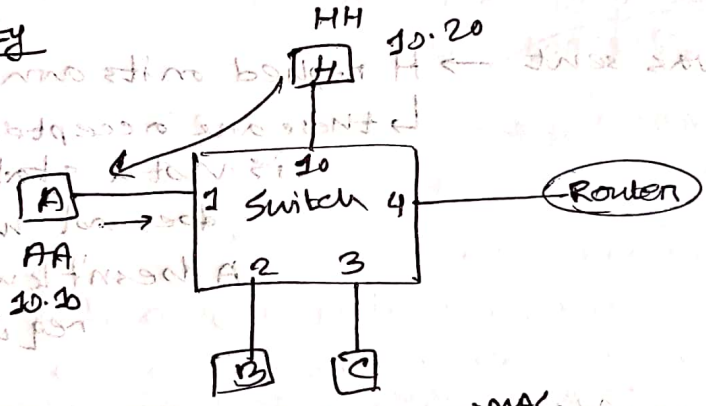
* using static entries → solves the problem → but the issue

switch → witness of the manipulations.

25/07/2026

CT ⇒ ch-03 → FS,03, ch-04 → malware.

Network Security



arp -a ⇒ lists the ARP resolutions. → ARP cache.

ARP spoofing → somebody sent wrong info

A asked C, H replied.

A — ARP cache

10.5	→ HH

→ poisonous entry.

↳ wrong MAC addr

impact of ARP spoofing attk

Ⓐ why is this possible?

TCP/IP → by default machines trust each other.

LAN assumption → all are trustworthy

↓

TCP/IP inherent assumption.

⊗ malicious agents in LAN → increasing day by day

⇒ ⊗ do not allow outsiders to connect to the LAN.

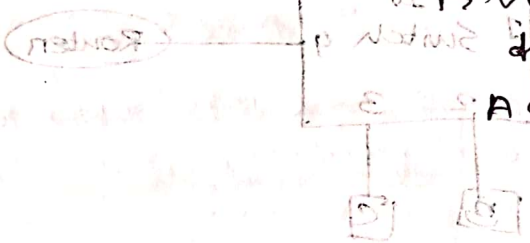
⊗ ARP req → broadcast

no way to distinguish whether the reply is from the intended device → no signature

also possible ⊗ no req was sent → H replied on its own.

↳ these are accepted as this is not a state machine does not maintain states.

A doesn't know whether req was sent.



⇒ Man-in-the-middle using ARP spoofing

Defense

→ S/W detection using some script

→ static entry ⇒ ARP cache will be typed statically manually.

↳ done in very secure LANs.

↳ dynamic ARP not used.

192.168.0.1 / 192.168.1.1 ⇒ access routers.

MAC filtering ⇒ only fixed devices can access the LAN.

Other DHCP req → ✗

↳ need to know the MAC addn.

→ multiple occurrence of the same MAC

10.5 → HH
10.4 → HH
10.1 → HH

diff IP, same MAC

hacker

this machine is performing ARP spoofing

→ dynamic ARP inspection (DAI) by switch → switch is not supposed to do this

→ becomes slow

packet forwarding

(or) ⇒ switch monitors the ARP msg.

can track the lying device

10.1, 10.5, 10.10

→ diff IP in replies.

~~MAC plugin atk~~

MAC-table flooding Attack → attack on switch

Switch

MAC-address-Table → not ARP cache.

initially empty.

Port #	MAC-Address
1	AA
2	BB

learns these mappings & preserves them

A → B packet

src : AA

dst : BB

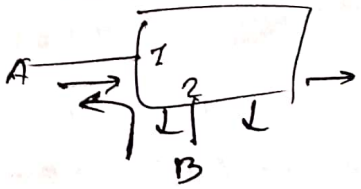
enters via port 1.

exit → unknown

send to all → broadcast

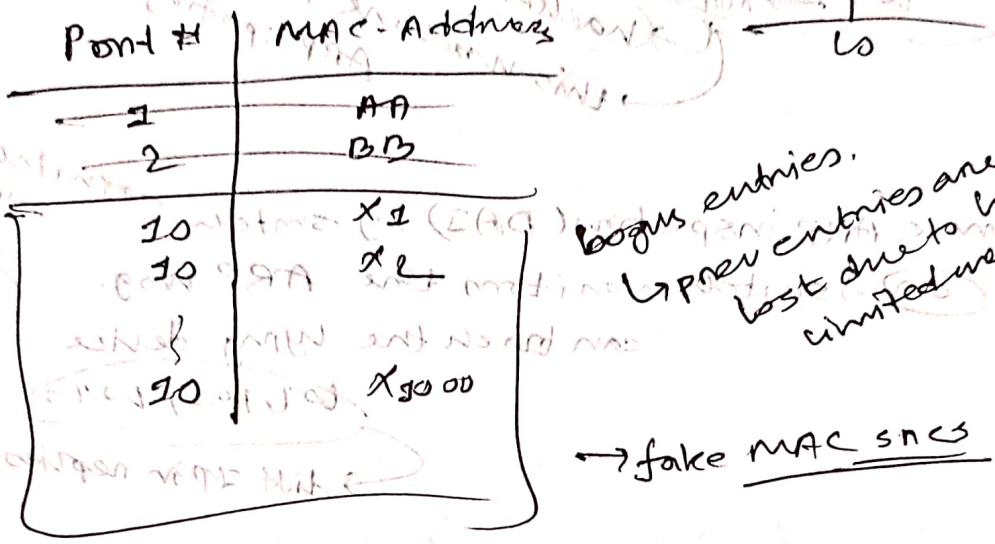
reply → src: BB.

↳ unicast to A



hacker ⇒ won't receive any msg

A → B
B → A



bogus entries.
↳ prev entries are lost due to having limited memory.

→ fake MAC snes

→ no more valid entries
A sends something to B ⇒ H gets this broadcast

⇒ the switch behaves like a hub.
↳ successfully degraded it.

MAC flooding atk → very popular.
↳ learn about the pckts in the LAN.

DoS atk on switch
↳ network BW decreases as all msgs are broadcast.

useful BW ↓

prevention

practice packet tracer

port security.

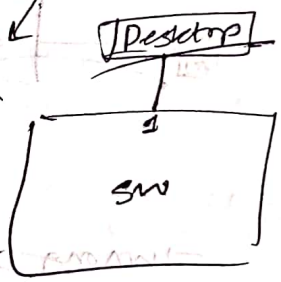
switchport port-security

draw this when explaining.

int fa0/1
switchport port-security
" "
" "
" "
max 1
violation shutdown.

MAC flooding not possible anymore.

another MAC at the same port → violation of port security
↳ disables port 1
⇒ only enabled when admin uses no shutdown



multiple devices ⇒ max 2/3.

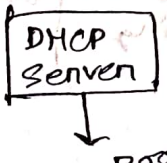
DHCP

DORA
discover
offer
request
ack

② atks
↳ DHCP starvation atk

DHCP Starvation Attack

Gobbler



pool → exhausted.
100 IPs

Discovering

MAC ~~req~~	IP
X1	10.1
X2	10.2
X100	10.100

same person exhausted the pool by using diff MAC addrs

real user → req → no IP left in the pool.

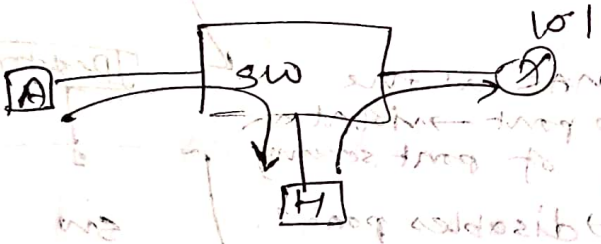
DHCP Spoofing Atk

No IPs left.

discover msg → broadcast

Rogue DHCP server provides false IP config.

⇒ fake default gateway → man-in-the-middle.



⇒ wrong DNS server → sends the server DNS addr.

- google DNS server → 8.8.8.8.
- ISP may use own DNS server

preventing DHCP atk

⇒ defense: snooping.

switch knows the port with the DHCP server. (setup)

↳ mark trusted ports

others by default untrusted.

eg.

offer msg from H against Discover

↳ fake msg → stop this from propagating } won't find

switch workload ↑

↳ need to check all packets

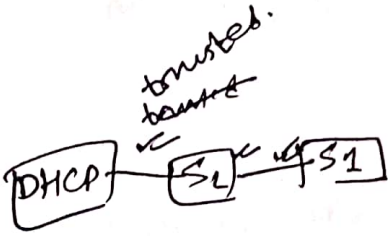
how to prevent starvation

rate limit

DHCP discover
limit => 3/min

untrusted port → limit rate. limits Discover msg

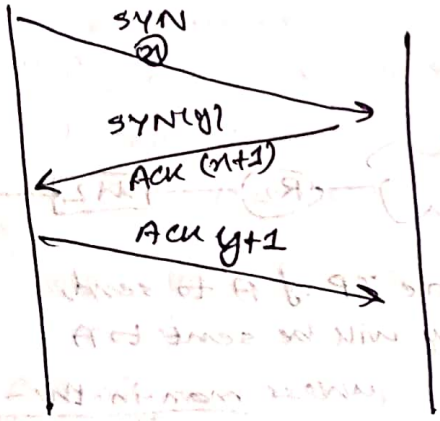
trusted → connected to infrastructure → known & static. config
switch, DHCP/DNS server
↳ configured manually.



26/06/26

TCP session Hijacking

client server 3-way handshake



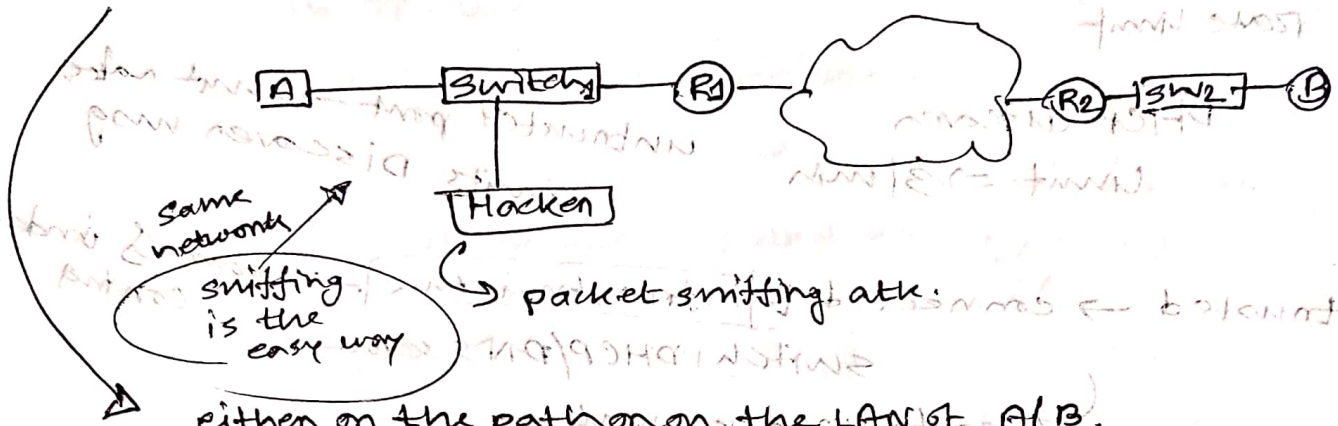
x=0, y=0 } may start with these values
↳ why this is not done!

at the beginning things were done this way.

someone may inject pckts midway → random seq# ↓ prevents this

the random seq# is known only to the client & the server.

Who else can get to know the seq#?



packet sniffing atk:

either on the path or on the LAN of A/B.

↳ Routers on the path may betray

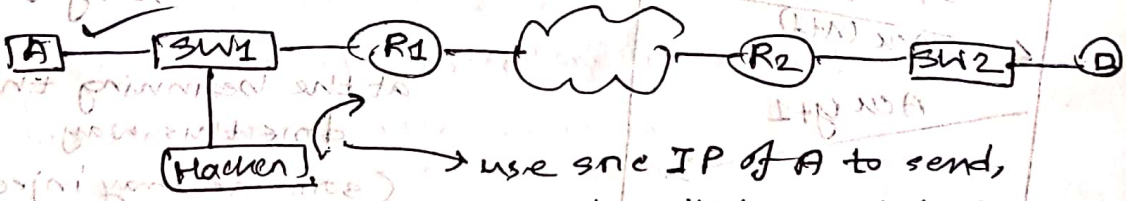
↳ MAC flooding,
ARP spoofing
DHCP starvation
DHCP spoofing.

blind TCP hijacking → w/o seeing anything, guess the seq#

2^{32} → wild guess → prob: $\frac{1}{2^{32}}$

blind TCP injection

↳ not on the path & no way to learn the random seq #



use src IP of A to send, reply will be sent to A unless man-in-the-middle is done

FlowID = (IP, port, IP, port)

A → B

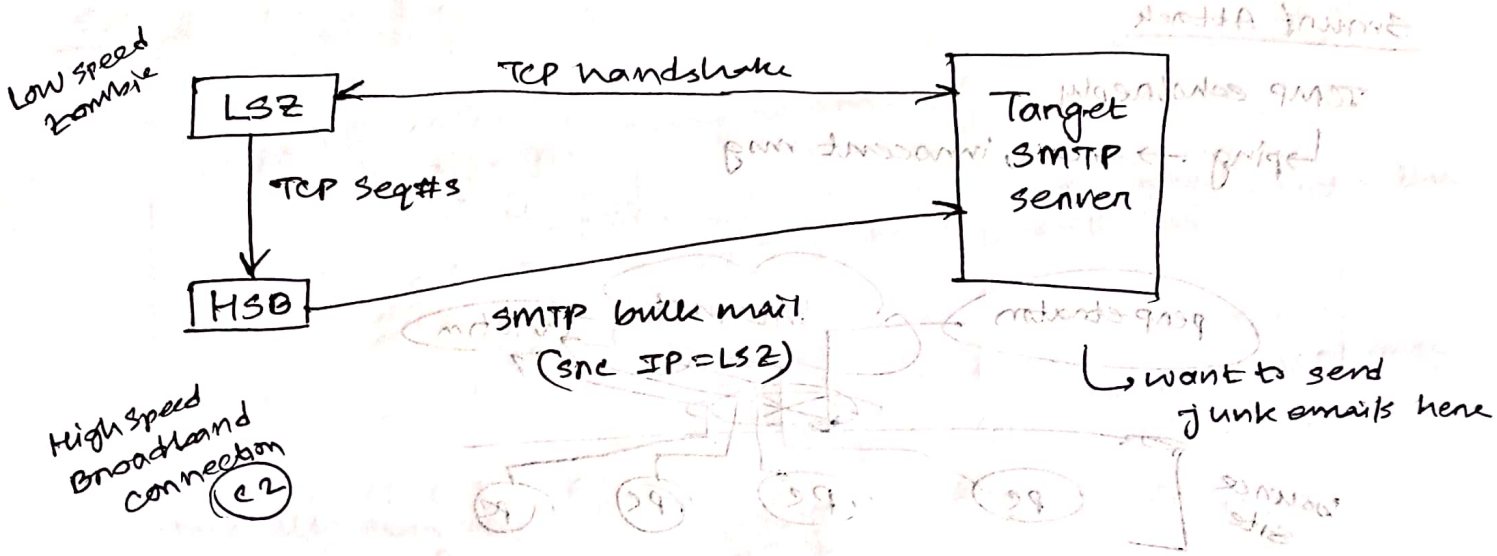
src dst

4 things

important!

Q ① How is man-in-the-middle related to session hijacking?

② What are the challenges in session hijacking if man-in-the-middle is not used?



Use the zombie to setup a connection with the server
use the seq# to send bulk mails to the server,

→ logs at the server will trace back to the zombie.

DoS attack

exhaust the computing resources at the server to make it crash / force restart

⇒ OS/program crash

using botnet

DDoS

using multiple computers to perform the atk

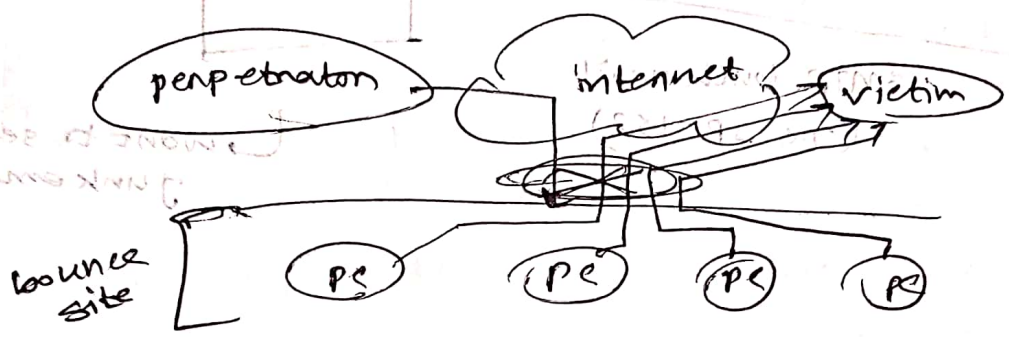
DoS Attack

1) Smurf Attack
2) SYN flooding Attack

Smurf Attack

ICMP echo/reply

↳ ping → small, innocent msg



ping
- src IP: victim IP
- dest IP: 192.168.10.255
  - ↳ broadcast

echo req hits everybody

everybody replies to the victim

254 replies for 1 req

↳ hit all the machines on my

larger network → more replies ⇒ flood the victim.

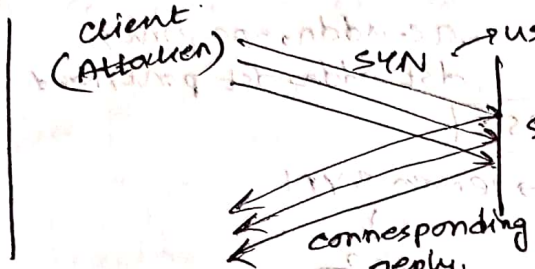
protection → routers may block the broadcast ping msgs.

↳ else smurf atk can be done

prevent being a "bounce site"

use the router to block

SYN flooding attack



server tries to establish the connections

Flow ⇒ C_1-IP, C_1-port, sIP, sPort
↳ this will change
C_3-
millions

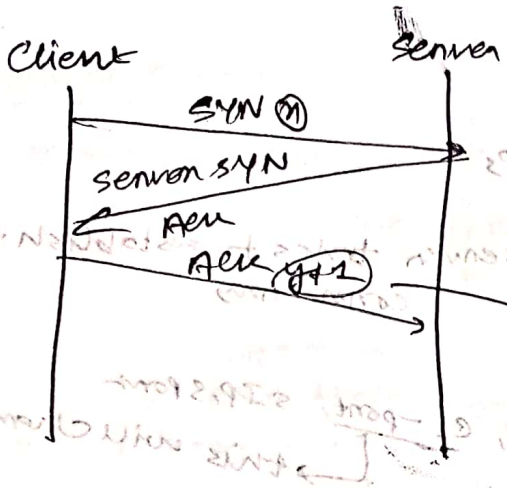
state allocation uses the memory & CPU resources.
↳ eventually exhausted ⇒ one kind of DoS attack

actual client sends SYN → memory is full.

* attacker always hides its own IP, unless it has a lot of bots.
many bots → use all bots → single atk → seems like usual.
↳ just perform DDoS,
IP spoofing is not needed.

Defense

main issue ⇒ millions of flow entries exhaust the memory.
↳ soln: $\mathcal{G}$ will not store the states.
only the actual clients send the third msg.
↳ before that do not consider it as a serious client



SYN cookie approach

SYN-cookie
server seq # will be computed using a function

src-addr, src-port, dst-addr, dst port, rand

f(.) = 251

252 → server SYN

252 − 1 = 251

$f^{-1}(251)$ → actual seq #

⇒ attacker does not get the 2nd msg as it does not have the IP used, spoofed IP.

spoof → works in one direction, original ← reverse → ✗

unless man-in-the-middle approach is used.

time mod 32 | MSS | cookie ⇒ total 32

5 bits

max segment size → 8 options.

3 bits

windows → does not use SYN cookies

some Linux distributions use it

attacks are only used on servers

IP traceback

↳ find the path.

try to find the src of atk, frequently, the atk uses bouncing

browser ⇒ ton → anonymity
↳ uses bouncing → works like a VPN.

logging challenges

↳ need to find the atk path in reverse.
↳ cannot be done if the intermediate routers do not help.

Ingress filtering

should be done by ISPs.

↳ (router will drop) IP based on domain

eg using chinese IP from BUET (not from BD)
↳ ISP ⇒ drops the pckt
eg BTCL

↳ spoofed IP pckts will be blocked

FW ⇒ may use ingress approach as well.

target ⇒ outside country → intl gateway router can use ingress filter → drop the pckt

⊛ cyber atk on other countries → disable this.
↳ but the other routers will notice the src.

↓

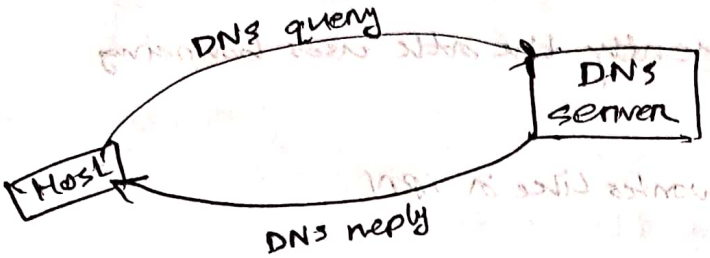
immediate neighbours → can detect these

else the last mean router.

CSE-405

DNS

27/06/26



this protocol uses UDP.

hackers may target the DNS, the main host is still up but cannot be reached as DNS resolution is not possible.

Load distribution

↳ distributes the load to different servers even if the same name is resolved.

Distributed

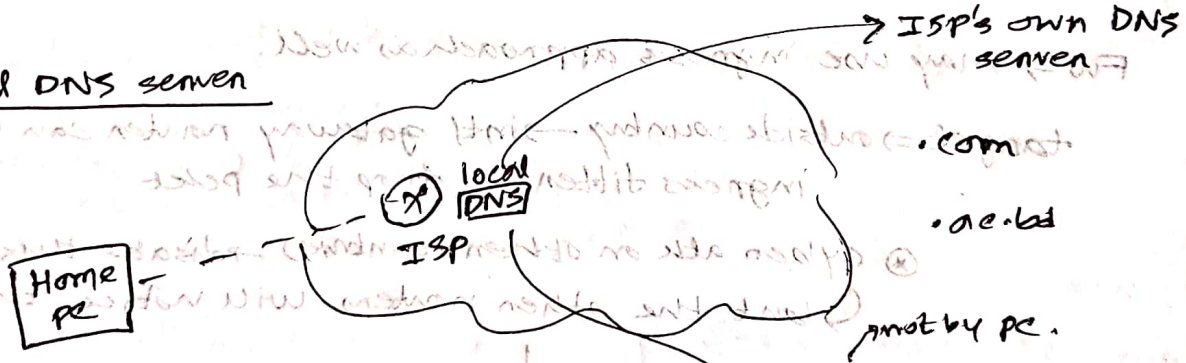
↳ Geographic.

centralized DNS → not used.

TLDs, ANS

↳ authoritative name servers

Local DNS server



initiates recursive/ iterative DNS resolution.

DNS

↳ cached when resolved

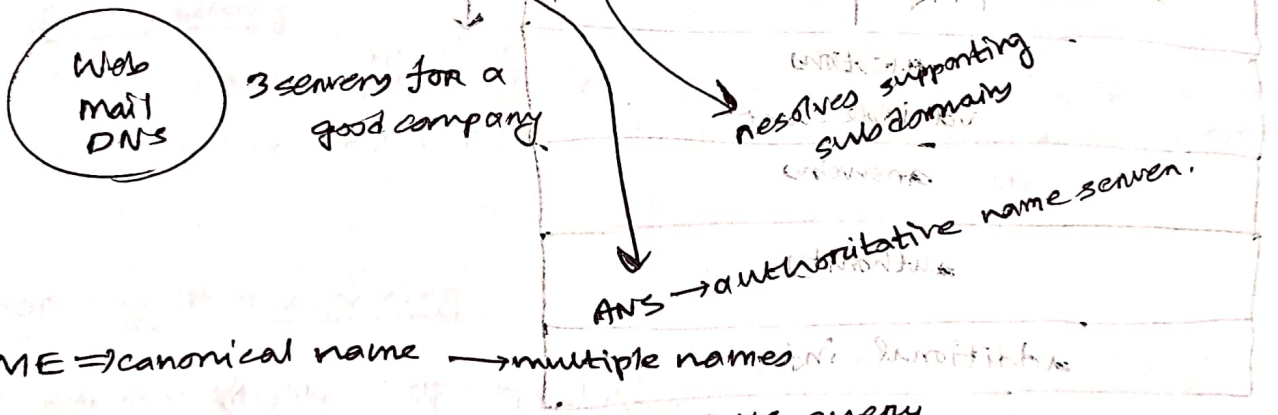
file → records

Domain	IP Value	Type	TTL
yahoo.com	1.2.5.8	A	60 sec
		MX	
		NS	
www.buet.ac.bd	1.2.5.8	A	60 sec
mail.buet.ac.bd	1.5.1.1	MX	
ns1.buet.ac.bd			

⇒ address record

⇒ mail server address record

⇒ name server address record



CNAME ⇒ canonical name → multiple names

⊛ nslookup www.amazon.com ⇒ DNS query

buet.ac.bd CNAME

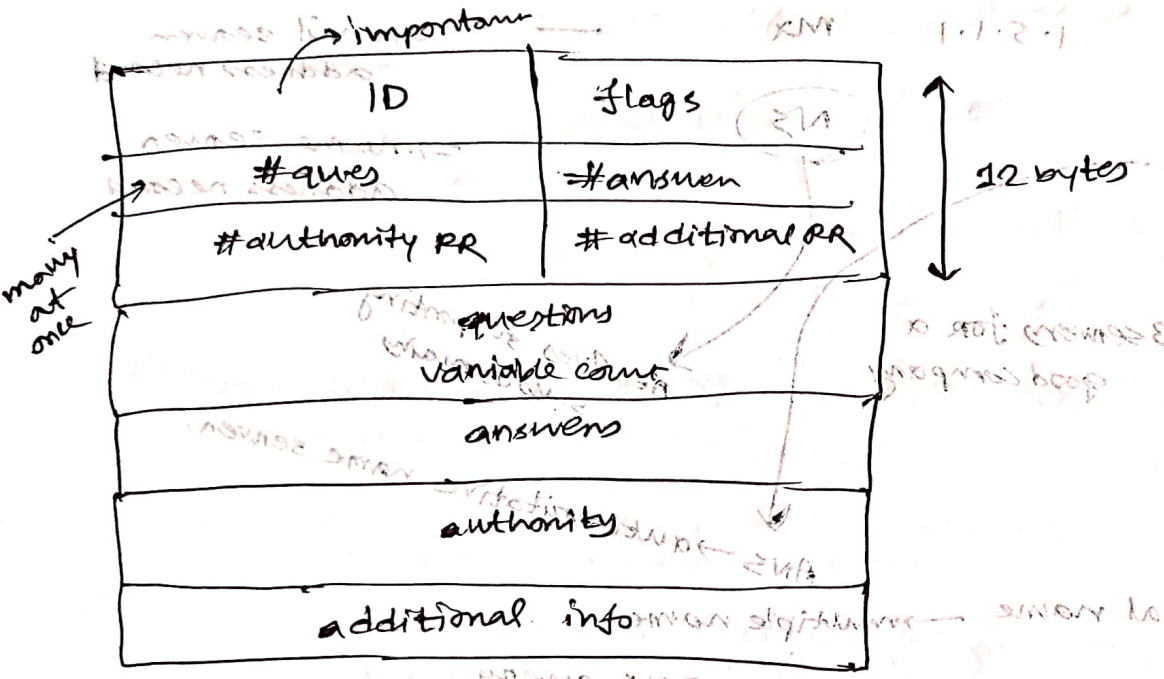
8.8.8.8 ⇒ google's DNS server → free

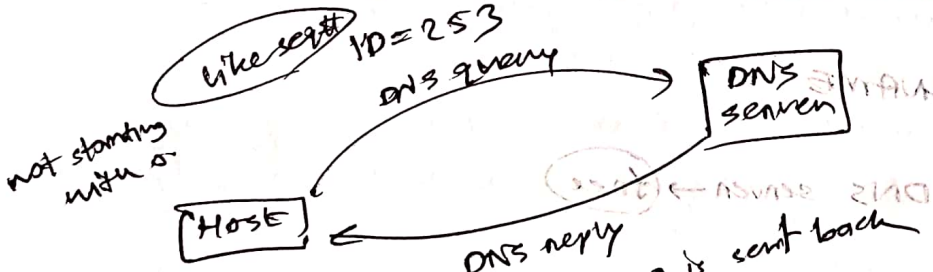
4.4.4.4 ⇒

DNS protocol, messages

query & reply msg

identification → 16 bits
flags → 16 bits





authoritative answer
↳ prob ✗ breach

may be due to cache
non-authoritative

authoritative DNS server

KU

www.buet.ac.bd
↳ may be resolved by KU-DNS

↳ resolve from ns1.buet.ac.bd → authoritative
↳ might be slow

UDP → 53

slide

ICANN ⇒ Internet Corporation for Assigned Names and Numbers → governing body

IETF ⇒ Internet Engineering Task Force

↳ all documentation / original spec for computer networks

RFC → request for ..

dynamic resolution

DNS caching

cache reply from ANS

problem → if the IP changes frequently

eg: servers that are constantly under DDoS atk. ↳ keeps changing IPs.

Pharming: DNS hijacking

Phishing attack

Pharming attack → DNS cache poisoning → ~~1.2.5.8~~ 11.12.13.14

↳ creating the look alike

↳ pharming

Vulnerability

↳ no encryption, can be intercepted.

reasons

1. most queries and responses are in plaintext
2. no authentication for response → fake reply
3. mostly UDP (TL) → no seq#, ack → easy to hack

protocol: DNS-SEC → digitally signed reply → can be cross checked

DNS cache poisoning

- Local DNS server
- Local PC cache
- original name server → hacked NS.

16-bit req ID → only send the IP

some NS may disregard the ID → anybody can reply.

DNS reply 5.5.5.5 (Fake) → needs to know the req ID

req is unicast msg → how to know

→ start from 0/predictable method

→ accept unsolicited reply (not requested), random reply.

↳ cache poisoned.

DNSSEC operation (fig)

each response (iterative/recursive) is digitally signed

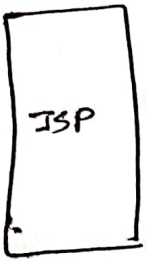
↳ slower due to encryption/decryption.

CSE-405

01/08/2026

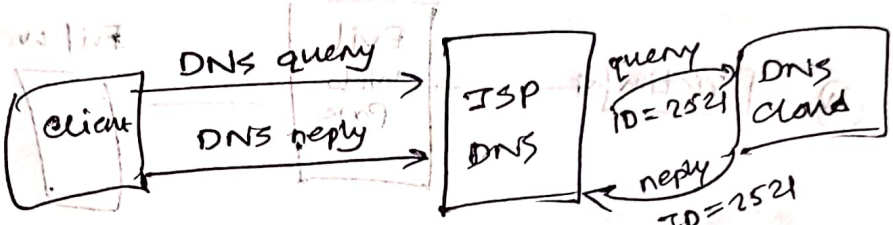
DNS Cache Poisoning

200k/500k
2000/5000
serverload



BTCL → user↑↑ load↑↑

10M/20M users.



evil client → attacker sends a corresponding reply for his own request.

if ISP matches the reply ID the atk will fail,
unless the client predicts the ID correctly.

multiple requests to DNS server

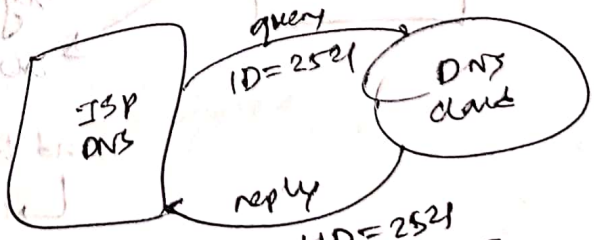
n requests → prob of guessing ↑

Birthday paradox

prob of two or more people sharing bday in a group of 23 > 50%.

prevention

- use IDs & match them
- randomize IDs → non-predictable
- port randomization → tough to guess
- DNSSEC



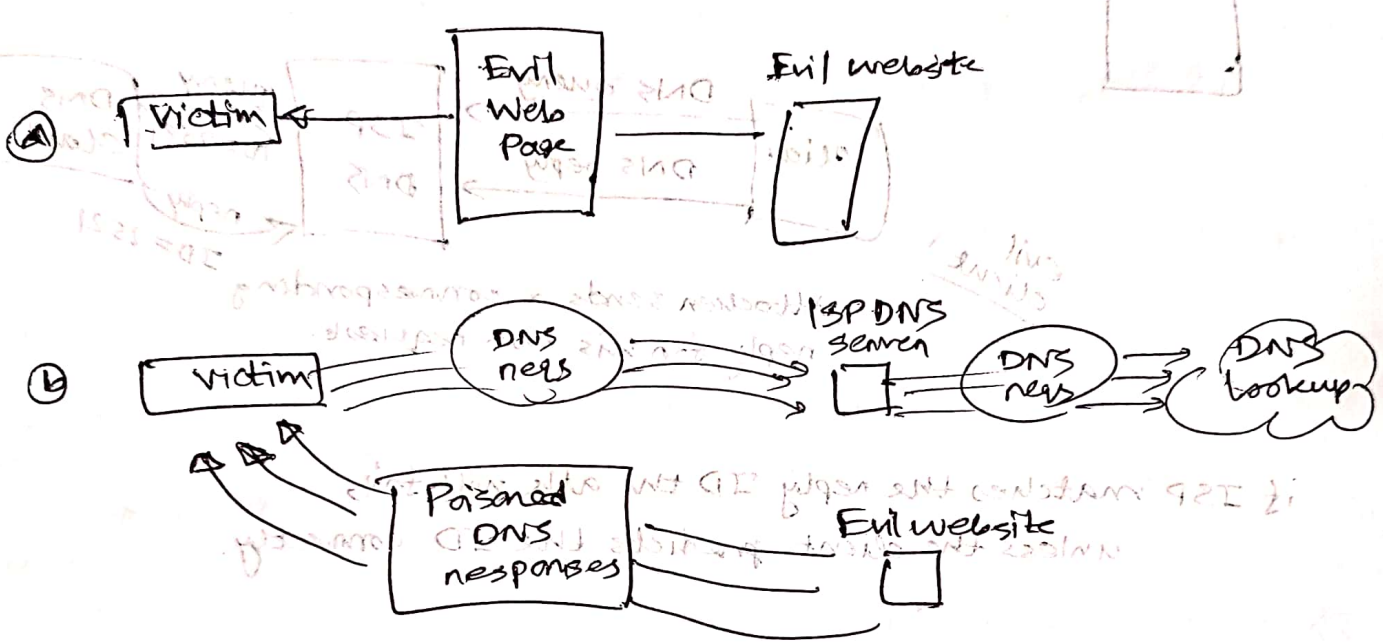
request ID=2521
src port=7925

query ID match } 2^{16}
src port } 2^{16}

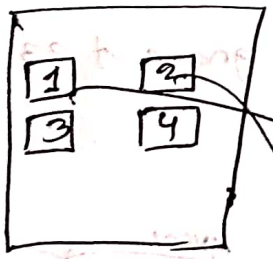
$2^{16} \times 2^{16}$ → prediction becomes more difficult

DNSSEC → protocol → enforces security on DNS
↳ digitally signed reply.

Client-side DNS Cache Poisoning Attacks



ittefaq.com/images/1.jpeg



images are loaded after the text

wrong DNS

xyz.com/images/1.jpeg

abc.com/images/2.jpeg

send to 4 diff sites
↳ 4 DNS reqs needed.
the evil website itself responds to these before the ISP DNS
↳ local client cache poisoned

(9)

(1) Cache poisoning from the website → client → victim

(2) Cache poisoning from the client → ISP DNS (cache poisoned)

cache poisoning by evil website.

src port randomization (SPR) → 16 bits → difficult to guess

Cybersquatting

registen a domain in anticipation of that domain being desirable to another organization → sell it for big profit later.

Typosquatting

registen all possible typo domains.

↳ generally not sold but large orgs may purchase these

{amazon.
amazzon.com}

↳ may use for phishing

↳ aliasing

DNSSEC

DNS replies are being spoofed

↳ digitally sign the response to ensure authenticity.

sign with private key
verify with public key.

iterative → all responses are digitally signed

reply based atk → ✗

60% of DNS servers use DNSSEC

BD → 90% do not use DNSSEC

Section A